FORMACIÓN EN CIBERSEGURIDAD — COMISIÓN 1

TRABAJO PRÁCTICO DE MITAD DE CURSADA

PRÁCTICA INTEGRADORA DE CIBERSEGURIDAD

Investigación de vulnerabilidades críticas: CVE-2017-0144 (EternalBlue), CVE-2021-41773 (Apache HTTP Server), CVE-2021-44228 (Log4Shell), CVE-2020-1472 (Zerologon) y CVE-2019-0708 (BlueKeep)
Análisis en profundidad y auditoría práctica de laboratorio en Kali Linux

Integrantes	Theo Cervera, Ale Modica
Comisión	Comisión 1
Instancia	Trabajo Práctico de Mitad de Cursada — Práctica Integradora
Fecha de entrega	Octubre de 2026

Índice de Contenidos

1. Investigación de vulnerabilidades 3

1.1. CVE-2017-0144 (EternalBlue) 3

1.2. CVE-2021-41773: Apache HTTP Server (Path Traversal y RCE) 4

1.3. CVE-2021-44228: Vulnerabilidad Log4Shell en Apache Log4j 5

1.4. CVE-2020-1472: Zerologon en Active Directory 6

1.5. CVE-2019-0708: BlueKeep en Escritorio Remoto (RDP) 7

2. Análisis de una vulnerabilidad I (CVE-2021-41773 - Apache) 8

2.1. Causas de la vulnerabilidad 8

2.2. Herramientas para analizar y detectar la vulnerabilidad 8

2.3. Propuesta de solución justificada 8

3. Detección o demostración de la vulnerabilidad II (Laboratorio Kali Linux) 9

3.1. Identificación de versiones con Nmap y auditoría de configuración 9

3.2. Verificación del servicio web y bloqueo del retroceso estándar (../) 10

3.3. Demostración de la vulnerabilidad CVE-2021-41773 en Apache 2.4.49 11

3.4. Verificación de la mitigación en la versión parcheada (Apache 2.4.68) 12

4. Fuentes Consultadas 13

1. Investigación de vulnerabilidades

1.1. CVE-2017-0144 (EternalBlue)

EternalBlue es un exploit filtrado en abril de 2017 por el grupo “Shadow Brokers”, que aprovecha una falla crítica documentada por Microsoft en el boletín MS17-010. Afecta a la versión 1 del protocolo SMB (Server Message Block) de Windows, utilizado en la Capa de Aplicación del modelo TCP/IP, específicamente sobre el puerto TCP 445 (y NetBIOS en los puertos 137-139).

Explicación: El protocolo SMB es el mensajero que utilizan las computadoras Windows en una red para compartir carpetas e impresoras. Cuando una PC le envía a otra una lista de atributos mediante SMB, primero le notifica los términos en los cuales se enviará el paquete de datos, entre los cuales se encuentra el tamaño; en este último punto es donde se encuentra la vulnerabilidad. Por un error matemático de conversión de tamaño en el controlador de Windows (controlador “srv.sys”), un atacante puede enviar un paquete manipulado engañando a Windows para hacer que reserve menos memoria de la que debería, lo que ocasiona un desbordamiento de búfer (Buffer Overflow). Los datos desbordados fuera de la caja reservada invaden la memoria del núcleo del sistema (Kernel), la cual está protegida, permitiendo ejecutar órdenes con control total sin estar autenticado como administrador. Otra característica de la explotación de esta vulnerabilidad es el hecho de ser autopropagable debido a las características mencionadas en el protocolo SMB; esto abrió puertas a que la explotación de esta vulnerabilidad se lleve a cabo sobre todo por atacantes mediante programas maliciosos de tipo ransomware.

Activos afectados:

- **Sistemas operativos y servidores:** Equipos con Microsoft Windows previos a marzo de 2017 sin el parche MS17-010 y con SMBv1 activo.
- **Infraestructura crítica y datos:** Servidores de archivos, controladores de dominio Active Directory, equipos médicos e industriales, exponiendo documentos corporativos, credenciales en memoria y discos completos al cifrado por ransomware.

Identificación:

- **Escaneo con Nmap:** Verificando si el puerto TCP 445 figura en estado OPEN y utilizando el script NSE de verificación:

```
nmap -Pn -p 445 --script smb-vuln-ms17-010 <ip>
```

Impacto y ejemplos reales de explotación:

- **WannaCry (mayo de 2017):** Infectó a más de 200.000 equipos en 150 países en cuestión de horas. Paralizó hospitales del NHS británico, plantas automotrices y empresas de telecomunicaciones (como Telefónica) cifrando discos duros y pidiendo rescates en Bitcoin.
- **NotPetya (junio de 2017):** Disfrazado de ransomware, funcionó como un limpiador (wiper) destructivo. Afectó a la naviera global Maersk, paralizando terminales portuarias enteras y causando pérdidas estimadas en más de 10.000 millones de dólares.

Medidas de mitigación:

- **Parcheo:** Aplicar el mencionado boletín MS17-010.

- **Deshabilitación de SMBv1:** SMBv1 es un protocolo obsoleto. Se debe deshabilitar por completo mediante PowerShell o GPO forzando el uso exclusivo de SMBv2/v3:

```
Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol
```

- **Firewall:** Bloquear el puerto TCP 445 en los firewalls perimetrales e internos.

1.2. CVE-2021-41773: Apache HTTP Server (Path Traversal y RCE)

CVE-2021-41773 es una vulnerabilidad descubierta en octubre de 2021 en Apache HTTP Server versión 2.4.49 (y su parche incompleto de la versión 2.4.50). Esta vulnerabilidad permite realizar un ataque de Path Traversal (salto o recorrido de directorios) y una potencial ejecución remota de código (RCE) a través de los puertos web TCP 80 y TCP 443.

Explicación: Dentro del diseño del funcionamiento de un servidor web, se decide qué carpetas serán visibles a los determinados públicos; en principio esto se hace situando al usuario en su debida carpeta e impidiéndole ir “hacia atrás” (a partir de cierto punto) para evitar que el usuario escale dentro de la jerarquía de carpetas del servidor y termine accediendo a carpetas con datos sensibles o privilegios elevados. La forma estándar de ir “hacia atrás” en un sistema operativo es con dos puntos (“..”); utilizar esta combinación de caracteres en un directorio es una orden implícita de “retroceso” dentro de la ruta actual. Debido a esto, se establecieron controles de seguridad donde se buscaba detectar la combinación estricta de “..” para bloquear el paso. En Apache, luego de una actualización de limpieza de rutas (“ap_normalize_path”), dejaron expuesta una vulnerabilidad debido a una falla muy simple: si el usuario escribía la combinación de caracteres “.%2e/” (donde “%2e” es la representación en hexadecimal del carácter “.”), no lo consideraba un retroceso, pero luego convertía el valor hexadecimal en “.”, permitiendo al usuario acceder a la combinación prohibida de “..” y, por consecuente, al comando de retroceso de carpetas dentro de la URL.

(Nota: luego de intentar ser solucionado en la versión 2.4.50, una vulnerabilidad similar siguió expuesta bajo el código CVE-2021-42013, donde se utilizaba la secuencia de doble codificación “%%32%65” para acceder nuevamente a la combinación de doble punto).

Activos afectados:

- **Servidores Web:** Servidores con Apache HTTP Server 2.4.49 o 2.4.50 donde el directorio raíz no tenga activa la directiva restrictiva por defecto.
- **Datos y aplicaciones comprometidas:** Archivos internos del sistema operativo, código fuente de sitios web y archivos de configuración.

Identificación:

- **Escaneo con Nmap:** Ejecutando el comando de detección de versiones sobre los puertos web:

```
nmap -sV -p 80,443 <ip>
```

- **Revisión de configuraciones:** Auditando el archivo apache2.conf / httpd.conf o ejecutando escaneos con Nessus, OpenVAS o Nikto.
- **Análisis de logs y tráfico en Wireshark:** Buscando en access.log o en capturas de red peticiones HTTP que contengan la combinación maliciosa.

Impacto:

- **Confidencialidad:** Lectura no autorizada de archivos privados del servidor, robo de código fuente y filtración de credenciales de bases de datos o claves privadas.
- **Integridad y disponibilidad (si mod_cgi está activo):** Ejecución de comandos como el usuario del servidor web, alteración de páginas web (defacement) o caída de servicio.

Medidas de mitigación:

- **Actualización de software:** Actualizar Apache HTTP Server a la versión 2.4.51 o superior.
- **Hardening de configuración:** Garantizar en apache2.conf la directiva restrictiva “<Directory /> Require all denied </Directory>” y deshabilitar módulos innecesarios como mod_cgi.
- **Protección perimetral en DMZ con WAF / IPS:** Colocar el servidor web en una DMZ detrás de un WAF o IPS (Suricata/Snort) que bloquee peticiones con secuencias de retroceso codificadas.

1.3. CVE-2021-44228: Vulnerabilidad Log4Shell en Apache Log4j

CVE-2021-44228 (conocida como Log4Shell) es una vulnerabilidad crítica descubierta en diciembre de 2021 en la librería de registro de eventos Apache Log4j (versiones 2.0-beta9 a 2.14.1) utilizada en aplicaciones Java.

Explicación: El error de Log4j ocurre al tener activada una función llamada Lookups (búsquedas JNDI), en la cual cualquier texto introducido entre “${...}” se interpretaba como una orden a ejecutar. Entonces, si un atacante ingresaba esta combinación en un campo de texto (que luego era registrado en los logs), podía hacer que el servidor descargara y ejecutara comandos remotos sin autorización.

Activos afectados:

- **Aplicaciones Java y servicios Cloud:** Servidores empresariales, sistemas bancarios y aplicaciones cloud que incorporen la librería log4j-core vulnerable dentro de su cadena de suministro de software (Supply Chain).

Identificación:

- **Análisis de código y archivos:** Buscando dependencias en pom.xml o archivos log4j-core*.jar en el disco para verificar si su versión es inferior a 2.17.1.
- **Escáneres y monitoreo de logs/red:** Escaneando con Nessus/OpenVAS y buscando con Wireshark cadenas “${jndi:” en los logs o conexiones salientes por el puerto TCP 389.

Impacto:

- **Control remoto total y fuga de credenciales:** Ejecución remota de código sin autenticación y robo de claves secretas de variables de entorno.

Medidas de mitigación:

- **Actualización y hardening de la JVM:** Actualizar Log4j a la versión 2.17.1 o superior, o iniciar la máquina virtual del proceso de Java con el parámetro “-Dlog4j2.formatMsgNoLookups=true”, además de bloquear conexiones salientes LDAP (puerto TCP 389) en el firewall perimetral.

1.4. CVE-2020-1472: Zerologon en Controladores de Dominio Active Directory

¿Qué se ve afectado y de qué manera? Afecta a los servidores que actúan como Controladores de Dominio (Domain Controllers) en entornos de Active Directory (Windows Server 2008 R2 hasta Windows Server 2019).

El problema radica en una falla criptográfica grave dentro del protocolo Netlogon Remote Protocol (MS-NRPC), utilizado para autenticar usuarios y máquinas dentro del dominio. Microsoft implementó el modo AES-CFB8 pero fijó el vector de inicialización (IV) en un valor constante de 16 ceros en lugar de generar un vector aleatorio para cada sesión. Criptográficamente, esto significa que tras una media de 256 intentos de conexión (un ataque de fuerza bruta que toma unos 3 a 5 segundos), un atacante puede autenticarse sin conocer la clave secreta y solicitar el cambio de contraseña de la cuenta del equipo del propio Controlador de Dominio, cambiándola a un valor vacío o nulo.

Problemática principal:

Es un colapso total de la seguridad de la identidad corporativa. Un atacante con solo un cable de red conectado a una toma física de la oficina (o con acceso a una máquina sin privilegios comprometida por phishing) puede convertir ese acceso mínimo en Domain Admin en menos de un minuto, obteniendo la base de datos NTDS.dit y controlando todas las cuentas, accesos y servidores de la empresa.

Ejemplos reales de explotación:

- **Cadenas de intrusión de Ransomware (Ryuk, Egregor, Conti):** En 2020 y 2021, múltiples bandas de ransomware incorporaron Zerologon en sus playbooks de movimiento lateral. Tras obtener acceso inicial mediante troyanos como TrickBot o QakBot, ejecutaban el exploit de Zerologon para adueñarse del Controlador de Dominio casi al instante y desplegar el cifrado en toda la red corporativa mediante GPO.
- **Campaña de amenazas persistentes avanzadas (APT):** Agencias de ciberseguridad como CISA (EE. UU.) alertaron sobre grupos de ciberespionaje patrocinados por estados que encadenaban vulnerabilidades en VPNs perimetrales con Zerologon para lograr persistencia total en redes gubernamentales.

Mitigación y prevención:

- **Aplicar parches en dos fases (Microsoft Rollout):** Instalar las actualizaciones acumulativas de agosto de 2020 y febrero de 2021, las cuales implementaron y forzaron el modo Secure RPC para todas las conexiones Netlogon.
- **Forzar canal seguro de Netlogon:** Asegurar que la directiva de dominio impida que dispositivos no compatibles o legados utilicen conexiones Netlogon no seguras.
- **Monitoreo y detección en logs:** Auditar en los Controladores de Dominio los eventos de seguridad de Windows con los IDs 4742 (“A computer account was changed”) y los IDs específicos de Netlogon (5827, 5828, 5829 y 5830) que alertan sobre intentos de autenticación RPC insegura.

1.5. CVE-2019-0708: BlueKeep en Servicios de Escritorio Remoto (RDP)

¿Qué se ve afectado y de qué manera? Afecta a los Servicios de Escritorio Remoto (RDP) en sistemas operativos anteriores a Windows 8: principalmente Windows 7, Windows XP, Windows Server 2008 y Windows Server 2003.

El fallo reside en el controlador termdd.sys. Ocurre durante la fase de negociación inicial del canal RDP (canal virtual estático interno MS_T120), antes de cualquier autenticación de usuario. Un atacante envía solicitudes maliciosas al puerto RDP (por defecto TCP 3389) provocando una condición de uso de memoria después de ser liberada (Use-After-Free). Esto permite ejecutar código arbitrario en modo kernel o provocar un fallo catastrófico inmediato del sistema (Blue Screen of Death o BSOD).

Problemática principal:

Al igual que EternalBlue, es pre-autenticación y potencialmente propagable (wormable). El riesgo crítico se dispara cuando organizaciones dejan servidores o estaciones con RDP expuestos directamente a Internet sin una VPN, permitiendo que escáneres masivos comprometan el equipo perimetral como punto de entrada inicial a la infraestructura.

Ejemplos reales de explotación:

- **Campañas de criptominería masiva (finales de 2019):** Aunque no desató un brote global destructivo del calibre de WannaCry gracias a la rápida respuesta de parches, grupos cibercriminales utilizaron módulos de BlueKeep (como el desarrollado para Metasploit) para escanear Internet, infectar servidores desprotegidos e instalar mineros de criptomonedas (Monero) en segundo plano.
- **Ataques de denegación de servicio (DoS):** Debido a que la memoria del kernel es inestable, muchos intentos fallidos de explotación por parte de actores de amenazas causaron caídas masivas (pantallazos azules) en servidores críticos de producción.

Mitigación y prevención:

- **Aplicar el parche oficial:** Instalar las actualizaciones de seguridad de Microsoft de mayo de 2019 (disponibles en el boletín oficial de BlueKeep, incluso con parches fuera de soporte para Windows XP y Server 2003).
- **Habilitar NLA (Network Level Authentication):** Exigir Autenticación a Nivel de Red para RDP. NLA obliga al cliente a autenticarse contra el sistema operativo antes de establecer el canal RDP, mitigando por completo la ejecución remota de código no autenticada.
- **Cerrar RDP a Internet:** No exponer el puerto TCP 3389 a redes públicas; acceder siempre mediante una VPN corporativa con autenticación multifactor (MFA) o mediante soluciones de acceso tipo Bastion / ZTNA.

2. Análisis de una vulnerabilidad I (CVE-2021-41773 - Apache)

Para el análisis en profundidad se selecciona la vulnerabilidad CVE-2021-41773 (y su variante CVE-2021-42013) en Apache HTTP Server, dado que permite comprender de forma directa cómo un error de validación de rutas y una configuración insegura derivan en la exposición de archivos internos del servidor.

2.1. Causas de la vulnerabilidad

- **Falla de programación (orden de decodificación):** La función ap_normalize_path() en Apache 2.4.49 verificaba si existían secuencias "../" antes de terminar de decodificar los caracteres hexadecimales de la URL. Al enviar ".%2e/" o "%2e%2e/", el filtro no detectaba los dos puntos seguidos y luego el servidor traducía "%2e" como un punto ("."), formando la secuencia "../" que permite retroceder carpetas.
- **Falla de configuración (permisos excesivos):** Para que el recorrido de directorios alcance archivos del sistema, el servidor debe tener modificada la configuración de seguridad por defecto en el directorio raíz ("<Directory />"), utilizando "Require all granted" en lugar de "Require all denied". Además, si mod_cgi está habilitado, el atacante no solo lee archivos, sino que puede ejecutar comandos invocando intérpretes del sistema.

2.2. Herramientas para analizar y detectar la vulnerabilidad

- **Nmap:** Permite identificar de forma activa si el puerto web (80 / 8080) está abierto y qué versión exacta de Apache está corriendo mediante el parámetro -sV (verificando si responde Apache 2.4.49 o 2.4.50).
- **Burp Suite Community Edition (Proxy / Repeater):** Permite inspeccionar en crudo las peticiones HTTP enviadas al servidor sin que el navegador web normalice o limpie previamente la ruta en el lado del cliente, verificando el comportamiento real ante rutas normales, rutas con puntos literales ("../") y rutas codificadas ("%2e").
- **Auditoría de archivos de configuración y logs:** Revisión local de httpd.conf / apache2.conf para comprobar las directivas <Directory /> y búsqueda en access.log de peticiones hacia /cgi-bin/ con secuencias codificadas.

2.3. Propuesta de solución justificada

- **Actualización a Apache 2.4.51 o superior:** Corrige de raíz la función ap_normalize_path() para que decodifique completamente cualquier secuencia hexadecimal antes de validar si existe un retroceso de directorio.
- **Principio de mínimo privilegio en httpd.conf / apache2.conf:** Asegurar que el bloque <Directory /> tenga la directiva "Require all denied" y deshabilitar mod_cgi. Así, incluso ante un error en la validación de la URL, el servidor deniega el acceso a cualquier archivo fuera de la carpeta pública web.
- **Defensa en profundidad (DMZ + WAF):** Ubicar el servidor web en una red DMZ aislada de la red interna y colocar un WAF que filtre peticiones con codificaciones anómalas antes de que lleguen a Apache.

3. Detección o demostración de la vulnerabilidad II

Modalidad seleccionada: Opción A — Demostración práctica y auditoría en laboratorio propio (Máquina Virtual Kali Linux). Se compiló e instaló la versión vulnerable Apache 2.4.49 junto con la versión parcheada Apache 2.4.68, definiendo como objetivo de prueba un archivo con una contraseña ficticia (/opt/laboratorio_ypf/clave_inventada.txt) alojado fuera de la carpeta web.

3.1. Identificación de versiones con Nmap y auditoría de configuración

En primer lugar, se ejecuta un escaneo de detección de versiones con Nmap sobre el entorno local (127.0.0.1). El escaneo permite distinguir inmediatamente la instancia actualizada de Debian en el puerto 80 (Apache 2.4.68) frente a la instancia vulnerable compilada en el puerto 8080 (Apache 2.4.49):

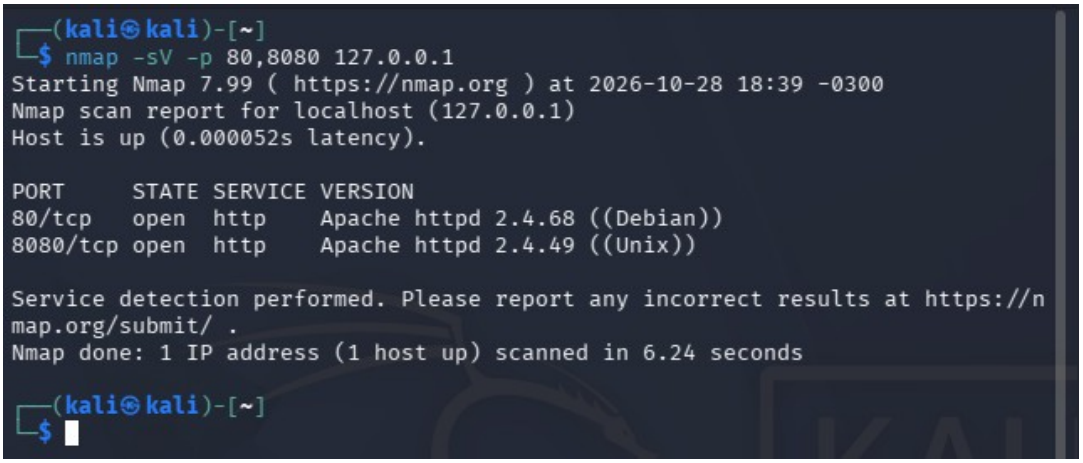


Figura 1. Escaneo con Nmap (-sV) identificando Apache 2.4.68 (puerto 80) y Apache 2.4.49 (puerto 8080).

A continuación, se auditan los archivos de configuración de ambas instalaciones para verificar la directiva de seguridad sobre el directorio raíz del sistema (<Directory />). En la instalación vulnerable (/opt/apache-2.4.49/conf/httpd.conf) se observa la directiva permisiva “Require all granted”, mientras que en la instalación segura (/etc/apache2/apache2.conf) se mantiene “Require all denied”:



Figura 2. Auditoría de httpd.conf en Apache 2.4.49 mostrando la configuración insegura (Require all granted).



Figura 3. Auditoría de apache2.conf en Apache 2.4.68 mostrando la configuración segura por defecto (Require all denied).

3.2. Verificación del servicio web y bloqueo del retroceso estándar (“../”)

Desde el navegador Firefox de la máquina virtual se comprueba que el servidor Apache 2.4.49 responde normalmente entregando la página principal (“It works!”) alojada dentro de su carpeta pública DocumentRoot (/opt/apache-2.4.49/htdocs/index.html):

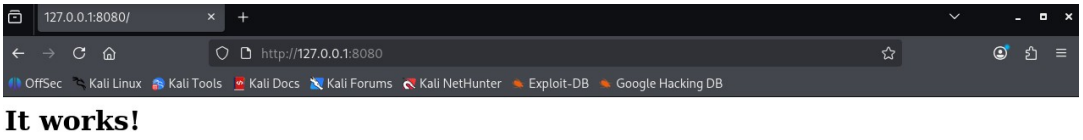


Figura 4. Comprobación desde Firefox del funcionamiento normal del servidor Apache 2.4.49.

Posteriormente, utilizando la herramienta Repeater de Burp Suite Community Edition, se evalúa qué ocurre cuando se intenta retroceder de carpeta utilizando los dos puntos literales (“../../”). Como se observa en la respuesta del servidor, el filtro estándar de Apache detecta la secuencia literal “..” y rechaza la petición devolviendo un error HTTP 400 Bad Request:

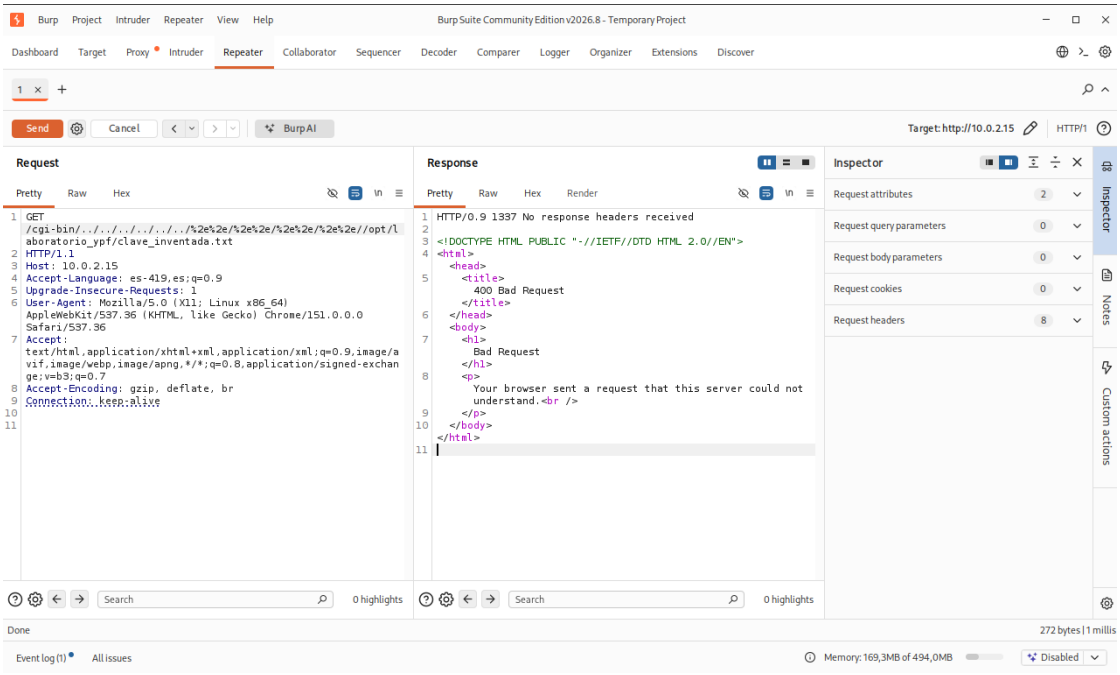


Figura 5. Prueba en Burp Suite: el intento de retroceso con puntos literales (../) es detectado y bloqueado con 400 Bad Request.

3.3. Demostración de la vulnerabilidad CVE-2021-41773 en Apache 2.4.49

Al reemplazar los puntos literales por su representación hexadecimal codificada (“.%2e/” y “%2e%2e/”) dentro de la petición enviada desde Burp Suite hacia Apache 2.4.49, se comprueba el fallo en la función ap_normalize_path(): el filtro inicial no reconoce el retroceso antes de la decodificación, luego traduce “%2e” a “.”, y permite escalar fuera de la carpeta web hasta alcanzar el archivo /opt/laboratorio_ypf/clave_inventada.txt, exponiendo en pantalla la contraseña de prueba (“CONTRASENIA_INVENTADA=YPF_Comision1_Segura_2026”):

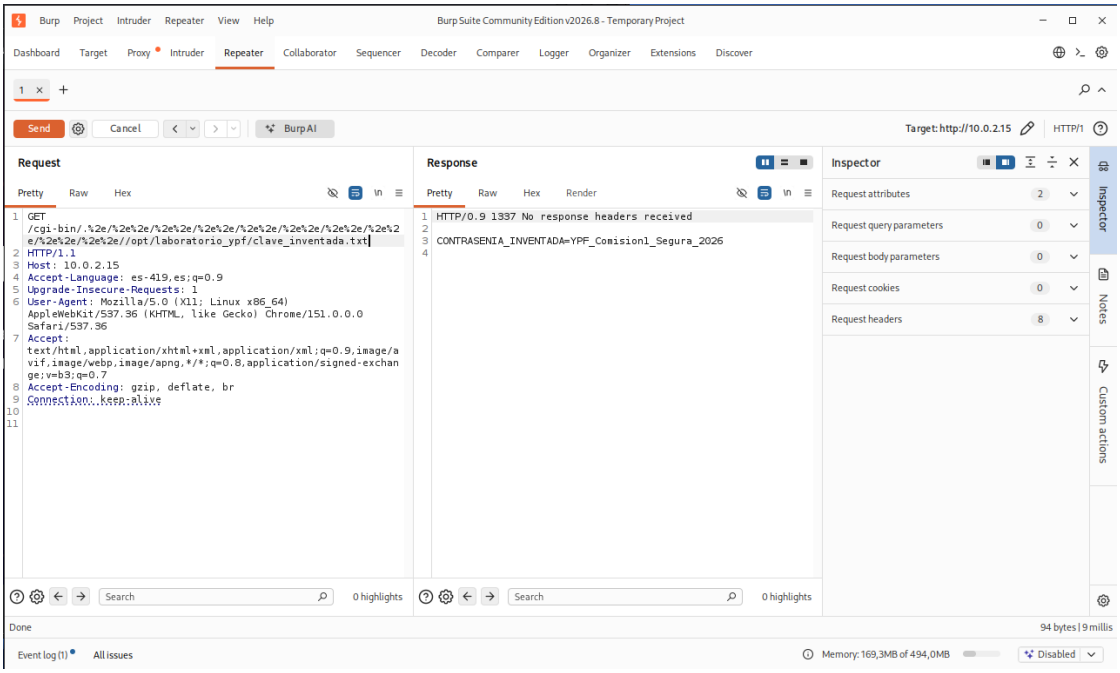


Figura 6. Demostración en Burp Suite sobre Apache 2.4.49: la secuencia codificada (%2e) evade el filtro y expone el archivo clave_inventada.txt.

3.4. Verificación de la mitigación en la versión parcheada (Apache 2.4.68)

Finalmente, se desactiva la instancia vulnerable Apache 2.4.49 y se activa el servidor actualizado Apache 2.4.68 (Debian) con la directiva restrictiva “Require all denied”. Al repetir exactamente la misma petición codificada desde Burp Suite Repeater, el servidor actualizado normaliza y detecta correctamente la secuencia “%2e” antes de procesar la ruta, bloqueando el ataque de forma inmediata con un código HTTP 400 Bad Request y protegiendo la confidencialidad del archivo:

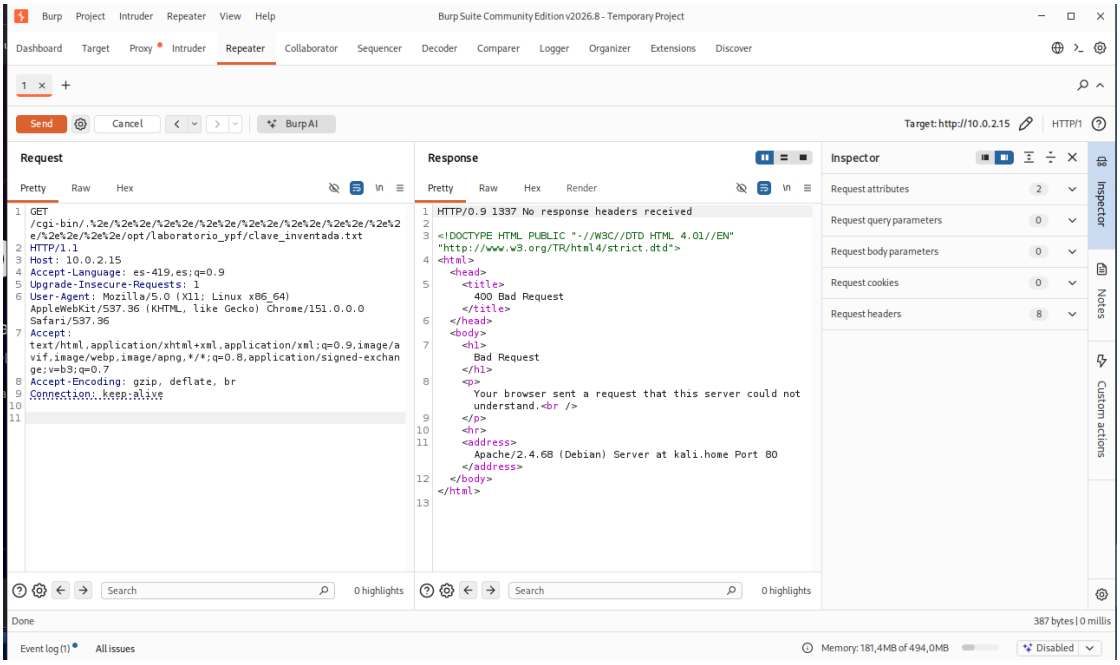


Figura 7. Verificación post-mitigación en Burp Suite: Apache 2.4.68 (Debian) bloquea la misma petición codificada devolviendo 400 Bad Request.

4. Fuentes Consultadas

- **NVD / NIST:** Base Nacional de Vulnerabilidades (registros CVE-2017-0144, CVE-2021-41773, CVE-2021-42013, CVE-2021-44228, CVE-2020-1472 y CVE-2019-0708).
- **Apache Software Foundation:** Apache HTTP Server 2.4 Vulnerabilities y Security Advisory para Log4j 2.
- **Microsoft Security Response Center:** Boletín de Seguridad MS17-010 (EternalBlue), aviso oficial de BlueKeep (CVE-2019-0708) y actualización de Netlogon (CVE-2020-1472).
- **CISA (Cybersecurity and Infrastructure Security Agency):** Alertas de seguridad sobre explotación activa de Zerologon (AA20-296B).
- **Material de cátedra:** Presentaciones de la cursada de Ciberseguridad (Clases 3 a 20).